Vulnerability Taxonomies

Matt Kijowski

10/29/26

Vulnerability Taxonomies

Objectives: Understand common vulnerability taxonomies, the standards behind them, and how they relate.

- U.S. National Vulnerability Database ***NVD***
- Common Platform Enumeration ***CPE***
- Common Vulnerabilities and Exposures ***CVE***
- Common Vulnerability Scoring System ***CVSS***
- Common Weakness Enumeration ***CWE***
- Common Attack Pattern Enumeration and Classification ***CAPEC***
- Adversarial Tactics, Techniques & Common Knowledge ***ATT&CK***
- Open Worldwide Application Security Project ***OWASP***

National Institute of Standards and Technology (NIST)

- Founded in 1901
- Standards organization responsible for weights, measurements, and cybersecurity standards
- Also has a solid (if small) page of memes



U.S. National Vulnerability Database *NVD*

- Run by the National Institute of Standards and Technology (NIST)
- Repository of standards-based vulnerability management data
- Includes databases of security checklists, software flaws, misconfigurations, product names, and impact metrics
- NVD takes each CVE and *enriches* it: affected products (CPE), weakness type (CWE), and severity (CVSS)

nvd.nist.gov

NVD can't keep up

- CVE submissions grew 263% from 2020 to 2025
- April 2026: NIST stopped enriching most CVEs
  - Every CVE is still listed, most are marked "Not Scheduled"
  - Priority goes to CISA KEV entries, software the federal government uses, and "critical software" (OS, browsers, hypervisors, IAM, . . .)
  - NVD now uses the CNA's CVSS score instead of scoring it again
- Lesson: a single database is a single point of failure, also check the vendor advisory and cve.org

Common Platform Enumeration *CPE*

- Basically just an official naming and versioning scheme for IT systems, software, and packages
- Try using it on one of your projects sometime!
- Contains a dictionary of platform names and versions to automate decisions based on known vulnerabilities

CPE

What's in a name?

- Why do we need a common detailed way to name something?
- Well Formed Name (WFN) == attribute-value pair set that can describe a number of products or identify a specific product
- WFN is a logical construct, the CPE is the specific data structure we care about

CPE naming scheme in a nutshell

From Wikipedia

`cpe:<cpe_version>:<part>:<vendor>:<product>:<version>:`
`<update>:<edition>:<language>:<sw_edition>:`
`<target_sw>:<target_hw>:<other>`

Traditionally, both a blank field or an asterisk `*` refer to a wildcard character.

Some examples:

- `cpe:2.3:o:microsoft:windows_11:-:*:*:*:*:*:*:*`
  Probably not specific enough for use in this class.
- `cpe:2.3:a:discord:discord:-:*:*:*:*:*:*:*` from cpe lookup

Common Vulnerabilities and Exposures *CVE*

- Reference method for publicly known information security vulnerabilities and exposures
- A CVE ID (`CVE-YYYY-NNNNN`) is a unique identifier for a single vulnerability
- Only CVE Numbering Authorities (CNAs) can assign CVE IDs
  - The CVE Program is run by MITRE and funded by CISA
  - Hundreds of CNAs: vendors (Microsoft, Oracle, Red Hat, etc.), open source projects, and research groups
  - MITRE is the CNA of last resort when no one else covers a product
- Each CVE record contains several specified fields

The CVE Program almost went dark

- April 2025: MITRE's contract to run CVE was about to expire
  - CISA signed an 11-month extension at the last minute
- The scare started backup plans
  - The CVE Foundation, a proposed independent home for CVE
  - The EU Vulnerability Database (EUVD), run by ENISA
- 2026: CISA made CVE a protected line in its budget

Think about it: should the world's vulnerability naming depend on one government contract?

CVE Further information and search

- CVE Wikipedia
- CVE.org Search (replaced the old `cve.mitre.org` search)
- NVD CVE Lookup

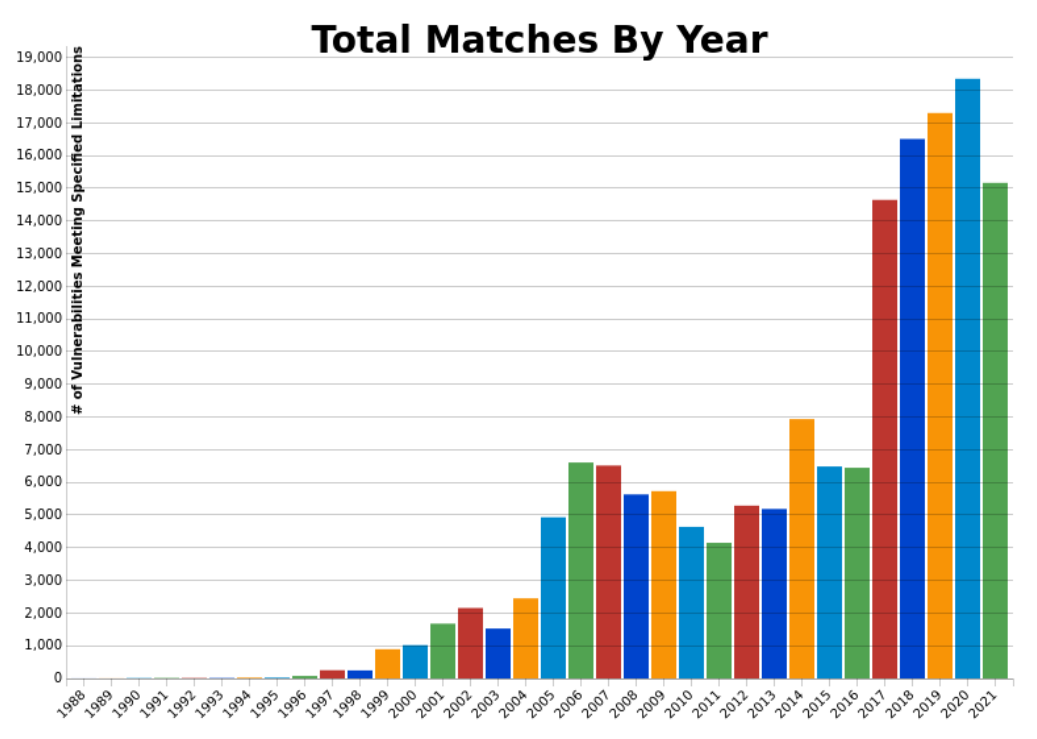


Figure 2: CVE per year

Common Vulnerability Scoring System *CVSS*

- Given the growing number of CVEs each year we need a way to focus on the most important ones
- CVSS assigns a numerical score based on the ***severity*** of a given CVE
- Scores range from 0 to 10, low being not very important and 10 being a critical security vulnerability
- Current version is CVSS v4.0 (2023), but v3.1 scores are still everywhere, be sure you are comparing the same versions
- Severity is not risk: a 9.8 on a box nobody can reach may matter less than a 6.5 on your VPN

CVSS Wikipedia | CVSS v4.0

Know your limits

NVD Dashboard

CVEs Received and Processed

Time Period	New CVEs Received by NVD	New CVEs Analyzed by NVD	Modified CVEs Received by NVD	Modified CVEs Re-analyzed by NVD
Today	0	0	0	0
This Week	436	30	0	8
This Month	2059	163	0	61
Last Month	2749	1310	0	746
This Year	7417	4263	0	1167

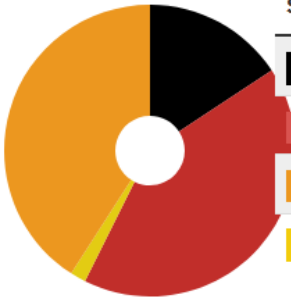
CVE Status Count

Total	242323
Received	128
Awaiting Analysis	3654
Undergoing Analysis	101
Modified	93929
Rejected	14007

NVD Contains

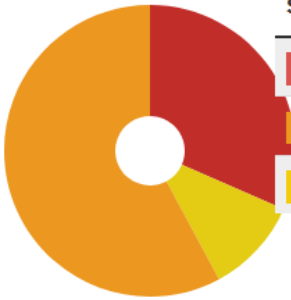
CVE Vulnerabilities	242323
Checklists	783
US-CERT Alerts	249
US-CERT Vuln Notes	4486
OVAL Queries	10286
CPE Names	1262384

CVSS V3 Score Distribution



Severity	Number of Vulns
CRITICAL	23013
HIGH	60925
MEDIUM	59882
LOW	2528

CVSS V2 Score Distribution



Severity	Number of Vulns
HIGH	56837
MEDIUM	104170
LOW	19074

More Acronyms (YAY! or maybe OMGWTFBBQ)

- **KEV** CISA's Known Exploited Vulnerabilities catalog, CVEs with evidence of exploitation in the wild
  - Federal agencies are *required* to patch KEV entries by a due date (BOD 22-01)
- **EPSS** Exploit Prediction Scoring System, 0 to 1 value with a ton of input (KEV, media, social media, security vendor info, etc.), establishing a *likelihood of exploitation* in the next 30 days
  - Currently on version 4 (2025)

KEV Catalog | EPSS model

Putting it together: what do I patch first?

1. Inventory what you run (CPE names)
2. Match your inventory to CVEs
3. Is it in KEV? Patch **now**
4. High EPSS? Patch **soon**
5. Use CVSS plus *your* environment to order the rest

Then ask *why* it happened (CWE) so it doesn't happen again.

Common Weakness Enumeration *CWE*

- Category system for software and hardware weaknesses
- A CVE is a specific bug, a CWE is the *type* of mistake behind it
- Over 950 weaknesses (CWE List v5.0) including
  - Cross-site scripting (CWE-79, #1 in the 2025 Top 25)
  - SQL injection (CWE-89, #2)
  - Path/directory traversal (CWE-22)
  - Hard-coded passwords, insecure random numbers... etc.

CWE over time | About CWE | CWE Top 25

Common Attack Pattern Enumeration and Classification *CAPEC*

- Public catalog of common attack patterns to help users understand how weaknesses are exploited
- Based on Software Design Patterns
- Relates weaknesses (CWE) and vulnerabilities (CVE)
- Similar to CWE, the same CAPEC may apply to many CVEs
- CAPEC-139: Relative Path Traversal attacks CWE-22

Attack Patterns Wikipedia | CAPEC Website

Adversarial Tactics, Techniques & Common Knowledge *ATT&CK*

- Knowledge base of real-world adversary behavior, built from observed attacks
- **Tactics**: the attacker's goal, the *why* (Initial Access, Persistence, Privilege Escalation, Lateral Movement, Exfiltration, Impact, . . .)
- **Techniques**: *how* they reach it (`T1566` Phishing, `T1078` Valid Accounts)
- **Groups**: known threat actors (nation-state APTs, ransomware crews) mapped to the techniques they use
- The more you know (or a more theatrical: know your enemy)

MITRE ATT&CK

CAPEC & ATT&CK

Use CAPEC for:

- Application threat modeling
- Developer training and education
- Penetration testing

Use ATT&CK for:

- Comparing computer network defense capabilities
- Defending against the Advanced Persistent Threat
- Hunting for new threats
- Enhancing threat intelligence
- Adversary emulation exercises

Open Worldwide Application Security Project *OWASP*

MITRE is just one (pretty big) organization. There are others that attempt to classify similar things.

OWASP is a community that attempts similar classification for just web applications.

- Best known for the **OWASP Top 10** (latest is 2025)
- Also maintains Top 10 lists for APIs, mobile, and LLM applications

OWASP Wikipedia | OWASP.org

OWASP Top 10:2025

1. Broken Access Control
2. Security Misconfiguration
3. Software Supply Chain Failures (new)
4. Cryptographic Failures
5. Injection
6. Insecure Design
7. Authentication Failures
8. Software or Data Integrity Failures
9. Security Logging and Alerting Failures
10. Mishandling of Exceptional Conditions (new)

Think about it: injection is #5 here, but XSS and SQLi are #1 and #2 in the CWE Top 25. Why?

Lab 5: NIST Vulnerability Taxonomies

Everything from today gets used in Lab 5:

1. **Inventory**: find 5 real CPE names for software on your laptop
2. **CPE**: write a well formed CPE (with a sem-ver version) for code *you* wrote
3. **CWE**: pick a Top 25 weakness that code had, and find real CVEs with it
4. **CVE**: write the CVE for your own bug, CVSS score included (I'm your CNA)

Read before you start: CWE Top 25 | Top 10 KEV Weaknesses | Semantic Versioning 2.0.0